



HTTP Headers Cheat Sheet

By Eric H

This cheat sheet helps you quickly reference the most important HTTP headers for web development, APIs, security, caching, and debugging. Use it to optimize requests, responses, and server behavior.

Tip

The complete web developer roadmap at thedevspace.io.



1. Request Headers

Sent by the client (browser, API, etc.) to provide info about the request.

```
1 GET /api/data HTTP/1.1
2 Host: example.com
3 User-Agent: Mozilla/5.0
4 Accept: application/json
5 Authorization: Bearer <token>
6 Cookie: sessionId=abc123
7 Referer: https://mysite.com/
8 Origin: https://mysite.com
9 Content-Type: application/json
```

Common Request Headers

- **Host** : Target server domain.
- **User-Agent** : Info about client/browser.
- **Accept** : Expected response format (e.g., `application/json`).
- **Authorization** : Credentials for authentication.
- **Cookie** : Cookies sent by client.
- **Referer** : URL of previous page.
- **Origin** : Origin of request (CORS).
- **Content-Type** : Format of request body (e.g., `application/json`).
- **Accept-Encoding** : Compression supported (e.g., `gzip`).
- **Cache-Control** : Client-side caching instructions.



2. Response Headers

Sent by the server to provide info about the response and control client behavior.

```
1 HTTP/1.1 200 OK
2 Content-Type: application/json
3 Content-Length: 123
4 Set-Cookie: sessionId=abc123; HttpOnly; Secure
5 Cache-Control: max-age=3600
6 Expires: Wed, 21 Jun 2024 10:00:00 GMT
7 Location: /login
8 Access-Control-Allow-Origin: *
9 ETag: "abc123"
10 X-Frame-Options: DENY
11 Strict-Transport-Security: max-age=63072000;
    includeSubDomains; preload
```

Common Response Headers

- **Content-Type** : Format of response body.
- **Content-Length** : Size of response body in bytes.
- **Set-Cookie** : Set cookies on client.
- **Cache-Control** : Caching instructions for client/proxy.
- **Expires** : When response expires.
- **Location** : Redirect URL.
- **Access-Control-Allow-Origin** : CORS: allowed origins.
- **ETag** : Unique identifier for resource version.
- **X-Frame-Options** : Prevent clickjacking (**DENY** , **SAMEORIGIN**).

- `Strict-Transport-Security` : Enforce HTTPS.
- `Content-Security-Policy` : Restrict resources and scripts.
- `X-Content-Type-Options` : Prevent MIME type sniffing (`nosniff`).
- `X-XSS-Protection` : Enable XSS filter (legacy).
- `Referrer-Policy` : Control Referer header sent.



3. Security Headers

Protect your site and users from common attacks.

```
1 Strict-Transport-Security: max-age=31536000;  
  includeSubDomains; preload  
2 Content-Security-Policy: default-src 'self'  
3 X-Frame-Options: SAMEORIGIN  
4 X-Content-Type-Options: nosniff  
5 X-XSS-Protection: 1; mode=block  
6 Referrer-Policy: no-referrer  
7 Permissions-Policy: geolocation=(), camera=()
```

Key Security Headers

- **Strict-Transport-Security** : Force HTTPS.
- **Content-Security-Policy** : Restrict allowed sources for scripts, styles, etc.
- **X-Frame-Options** : Prevent site from being embedded in iframes.
- **X-Content-Type-Options** : Prevent MIME type sniffing.
- **X-XSS-Protection** : Enable browser XSS filter (legacy).
- **Referrer-Policy** : Control Referer header sent.
- **Permissions-Policy** : Control browser features (camera, geolocation, etc).

4. Caching Headers

Control how browsers and proxies cache your content.

```
1 Cache-Control: public, max-age=86400
2 Expires: Wed, 21 Jun 2024 10:00:00 GMT
3 ETag: "abc123"
4 Last-Modified: Tue, 20 Jun 2024 09:00:00 GMT
5 Pragma: no-cache
```

Key Caching Headers

- **Cache-Control** : Main caching policy (e.g., **no-cache** , **max-age**).
- **Expires** : Date/time when resource expires.
- **ETag** : Resource version for validation.
- **Last-Modified** : Last update time for resource.
- **Pragma** : Legacy caching control.



5. CORS Headers

Control cross-origin resource sharing for APIs and web apps.

```
1 Access-Control-Allow-Origin: https://mysite.com
2 Access-Control-Allow-Methods: GET, POST, PUT
3 Access-Control-Allow-Headers: Content-Type,
  Authorization
4 Access-Control-Allow-Credentials: true
5 Access-Control-Expose-Headers: X-Custom-Header
```

- **Access-Control-Allow-Origin** : Allowed origins for requests.
- **Access-Control-Allow-Methods** : Allowed HTTP methods.
- **Access-Control-Allow-Headers** : Allowed request headers.
- **Access-Control-Allow-Credentials** : Allow cookies/auth.
- **Access-Control-Expose-Headers** : Expose custom headers to client.

6. Custom & Debug Headers

Use custom headers for tracking, debugging, and extra info.

```
1 X-Request-ID: 12345
2 X-Powered-By: Next.js
3 X-RateLimit-Limit: 1000
4 X-RateLimit-Remaining: 999
5 X-RateLimit-Reset: 1710000000
```

Examples

- `X-Request-ID` : Unique request identifier.
- `X-Powered-By` : Server/framework info.
- `X-RateLimit-*` : API rate limiting info.
- `X-Custom-*` : Any custom header for your app.